

ENGINEERING BRIEF · 2026-08

TokenMarket 技术架构说明

契约优先 monorepo：Go 网关吃代理流量，Python 服务拥有领域与持久化，React 拥有展示。本文描述仓库里已经跑起来的路径，并单独标出目标架构中尚未落地的部分。

阅读约定：凡写「已实现」均对应 services/、shared/contracts/、infra/、ops/ 中的现码。凡写「目标 / 不做」均来自 PRD、路线图或 项目开发/1-4 规范，不得画进当前部署图。冲突优先级：宪章 > 已接受 ADR > 现行 shared/contracts > 尚未落地的架构段落。

项	值
范围	V0.1：火山方舟 Chat Completions 代理主链路 + 身份/Key 领域
明确不做	多平台、Kafka 强制计量、扣费/Escrow/TMP、买家卖家管理前端、加权路由
听众	工程师、技术负责人；配套 2 小时分享 PPT
权威入口	docs/architecture/overview.md（现状） · 项目开发/1-项目架构与目录结构.md（目标）

1. 目录

1-3 用法与全景
 4 契约与工作流
 5-6 前端、身份、授权
 7-9 Key 与网关主链路
 10-13 观测、骨架、基础设施、SF 对照
 14 已知张力
 16-20 HTTP 全表、配置、时序、Alembic
 21 阅读清单

2. 本文档怎么用

TokenMarket 同时存在两张图。一张是已经能 make start 跑起来的 V0.1 现状；一张是 PRD 里的完整产品（Kafka、MinIO、Escrow、三端业务页、多平台加权路由）。混在一起讲，会把骨架服务讲成已上线计费，把进程内 Round-Robin 讲成智能路由。

2.1 两张图

层面	V0.1 现状	目标（未作为本期交付）
代理入口	仅 POST /v1/proxy/volcano/chat/completions	多平台、Embeddings、通用 /v1/chat/completions
路由	进程内等权 RR + 自买自卖排除 + inflight	延迟/价格/亲和加权、跨实例原子游标
计量	usage_logs 观察；缺 usage 不得填 0	实时扣余额、账单、Escrow
异步	本地 WAL / 事务；无 Kafka	Kafka 计量与审计
前端	注册 / 登录 / 工作台占位	/seller/* /buyer/* /admin/*
计费/管理	健康骨架	计费引擎、仲裁、看板 API

2.2 一句话架构

网关是火山 Chat Completions 的单进程适配器：Bearer HMAC 认证 → 选别人的卖家 Key → 允许列表过滤后一次上游调用 → OpenAI JSON 或 SSE → 一条用量观察。用户表、密文、会话在 api-service。网关不得拥有用户表或卖家 Key 密文的持久化。

3. 工程约束与所有权

3.1 宪章与边界

- Monorepo：Go 网关、Python 领域服务、React 前端、shared/contracts、infra/ops
- 所有权清晰。服务不得直连他服务数据库。
- 网关只做认证、限流、选路、转发、计量观察、健康与请求级遥测。领域工作流在 Python。展示在前端。
- HTTP 与事件契约先于消费者版本化。同步调用必须有界超时；只有已证明幂等的操作才自动重试。生成类请求禁止自动重试。
- 密钥、上游 Key、会话令牌不得入库明文、不得进日志/错误/夹具。
- PostgreSQL 是持久事实源；Redis 只保存可重建状态。启动不自动迁移。

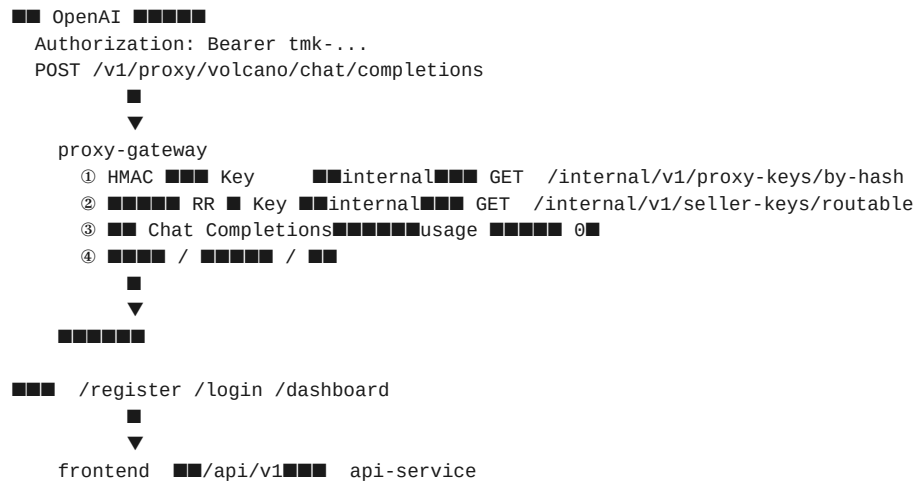
3.2 组件所有权

组件	语言	默认端口	拥有	不拥有
proxy-gateway	Go	:8080	公开代理、内部凭证验证、进程内 Key 池、指标	用户表、卖家密文持久化、扣费
api-service	Python	:8000	users / 会话 / 授权 / seller_api_keys / proxy_keys / usage_logs (迁移顺序 1)	上游 Chat 转发
billing-service	Python	:8001	健康/就绪骨架、空 Alembic 0001 (顺序 2)	扣费、账单、Escrow
admin-service	Python	:8002	健康骨架	迁移、业务路由、依赖探针
frontend	React 18	:5173	注册、登录、会话壳、工作台占位	卖家/买家 Key UI

4. 运行时全景

4.1 本地进程

日常入口是 make start : SF02 中间件 (PostgreSQL 15.18、Redis 7.2、Grafana OSS 13.0) 加五个主机应用进程。业务服务永不加入 compose.local.yml。Kafka 不在 SF02 依赖集。



4.2 成功与失败的两种 HTTP 形状

管理/业务接口使用统一包络 {code,message,data,request_id,timestamp}。成功的代理响应与已开始的 SSE 保持 OpenAI 形状。代理前置失败（认证、无可用的 Key、契约拒绝）使用统一包络，避免把内部细节泄漏给客户端。

5. 契约、工作流与 ADR

5.1 shared/contracts 目录

契约	所有者	管什么
repository-workflow/v1+v2	仓库	Make、mode、CI、健康 OpenAPI、工作流事件
local-environment/v1	仓库/infra	SF02 三依赖、工作区项目名、锁、探针
deploy-environment/v1	仓库/infra	make deploy, mode=test prod, 分层 Compose
user-registration/v1	api-service	POST /auth/register、手机规范化
phone-auth-session/v1	api-service	OTP 挑战、Cookie 会话、202-before-dispatch
role-access-isolation/v1	api-service	evaluate、角色矩阵、自买自卖排除
volcano-key-validation/v1	gateway	内部凭证验证, quota 禁填 0
volcano-openai-compat/v1	gateway	Chat 允许列表、SSE、usage 观察

008-019 的 HTTP 细节多数仍在 specs/NNN-*/contracts/，尚未提升进 shared/contracts 总表。新消费者不要复制模型，从契约生成类型。

5.2 公共 Make

- make start / stop : 本地默认。中间件 + 五个主机进程。
- make dev / dev-down : 只管理 PostgreSQL / Redis / Grafana。
- make deploy / deploy-down : 必须 mode=test|prod。ADR 003 Phase 1 在适配器落地前 fail-closed。
- make migrate : 按 owners.json, API → Billing。启动永不自动迁移。
- make ci : toolchain → bootstrap → fmt-check → type-check → lint → test → migrate-check → migrate-integration-check → security → build → smoke → image-scan。GitHub Actions 只调用 make ci。
- 环境从不从 Git 分支名推断，只用显式 mode=。

5.3 ADR

ADR	决策	状态
001	GitHub Actions 是 make ci 的只读薄适配层	Accepted
002	本地依赖走 Compose ；项目名 tokenmarket-<path-hash>	Accepted + Verified
003	分层 Compose ：local 不含业务镜像；deploy 独立入口	Accepted ；实现验证 Pending
004	托管工具链执行 profile ，不靠 CI= 猜测	Accepted

5.4 健康探针

所有服务提供 /health/live （进程活着即 200）与 /health/ready 。仅 api-service 与 billing-service 的 ready 探 PostgreSQL （一次 SELECT 1 ，2s ，不重试） 。Gateway 与 Admin 不得获得未声明的依赖探针；gateway ready 目前恒为 ready 。失败体只点名依赖 （如 postgres） ，不含 URL 、密钥或异常原文 。

6. 前端与身份

6.1 前端路由（真实 vs 占位）

路径	性质	行为
/	占位	平台首页占位
/register	真	POST /api/v1/auth/register；不自动登录
/login	真	OTP 挑战 + 建会话（cookie/CSRF）
/dashboard	受保护占位	展示脱敏会话；无 Key / 计费 UI
*	未开放	NotFound

同源 /api 代理到 api-service。credentials: include。禁止把 VITE_API_BASE_URL 指到 loopback :8000，否则 Secure cookie 会丢。没有 /seller/* /buyer/* /admin/*。

6.2 注册（SF03）

- POST /api/v1/auth/register，必须 Idempotency-Key。
- 大陆 11 位手机规范化；角色 buyer | seller | both。
- Redis 限流失败关闭。成功返回 user_id/role/status/phone_masked。
- 不签发会话。页面明确「尚未登录」。

6.3 登录会话（SF04）——不是 JWT

POST /verification-challenges 采用 202-before-dispatch：中性 202 与 pending 挑战先提交，再由内部 dispatcher 发短信。无论号码是否存在，对外形状相同（防枚举）。不存在的号码建 decoy 挑战（user_id=NULL），验码不会成会话。

POST /sessions 校验 6 位码（最多 5 次），撤销旧会话，签发新会话。Cookie 名 __Host-tokenmarket_session，值 <key-version>.<opaque-256bit>，Secure + HttpOnly + SameSite=Lax + Path=/，无 Domain，Max-Age 3600。库内只存 HMAC digest。响应体带 csrf_token（绑 session_id）。RBAC 每次从 users 现读角色，禁止用 role_snapshot。生产无批准短信通道则 fail-closed。

7. 授权与自买自卖

契约 role-access-isolation/v1，默认拒绝。请求体里的 user_id / role / buyer_id 必须忽略，身份只来自会话。

动作	buyer	seller	both
proxy_key.create / revoke / use	allow	deny	allow
seller_key.register / read / update / disable	deny	allow	allow
route_candidate_exclude_self	allow	deny	allow

7.1 三条路径不要混为一谈

- HTTP 矩阵：POST /api/v1/authorization/evaluate 与 /route-candidates/exclude-self。拒绝先写审计再 403/404；审计失败 503。
- Key HTTP 门禁：seller-keys / proxy-keys 用会话角色粗过滤 + 行级 seller_id/buyer_id，当前不调用 AuthorizationService。
- 真实代理路径：网关拉 /seller-keys/routable，Pool.Pick(buyerID) 跳过 SellerID==BuyerID。不调用 exclude-self。

resource_ownerships 表由 SF05 evaluate 与 fixtures 使用；运行时卖家/买家 Key 只写各自表的 seller_id/buyer_id，两套所有权尚未双写。讲架构时必须点名。

8. 卖家 Key

8.1 接入

POST /api/v1/seller-keys (seller/both, 必须 Idempotency-Key) 。仅 platform=volcano 。api-service 调网关
 POST /internal/v1/provider-credentials/validate (SF06, 3s 硬截止, 探 GET /models) 。额度读取器 V0.1 为
 NoopQuotaReader → error_category=quota_unavailable, 禁止假 0 。success 且额度>0 →
 health=healthy ; quota_unavailable 仍可持久化但 health=unknown, 不可路由。

8.2 加密

认证加密: SHAKE256 流 + HMAC-SHA256 tag ; nonce / ciphertext / tag
 分列存储; 密钥材料只在进程环 (版本化), 不与行一起持久化。读路径可 re-encrypt 到当前 key_version。指纹
 HMAC 在平台内去重 (DUPLICATE_CREDENTIAL, 对外不说「已被他人使用」)。响应只有 masked_hint。

8.3 生命周期

administrative_state : active ↔ paused → revoked 。pause 立刻不可路由 ; resume
 解密、再验证、额度>0、乐观版本 ; revoke 擦除密文, 再 resume → 409
 STATE_CONFLICT。健康状态由网关周期探活写回 POST /internal/v1/seller-keys/{id}/health, 不改
 administrative_state。

可路由 : administrative_state=active ∧ health_state=healthy ∧ 正额度 ∧ 有密文 ∧ 卖家账号
 eligible 。health=unknown 不可路由。

9. 买家代理 Key

POST /api/v1/proxy-keys (buyer/both) 。明文 tmk- + ≥ 128 bit hex ; secret_hash = HMAC-SHA256(pepper,
 secret) 。明文只在创建响应出现一次, 幂等重放不再回显。列表只给 masked_suffix。撤销 status=revoked。

网关认证: 解析 Bearer → 校验 tmk- 形态 → 本地用 PROXY_AUTH_PEPPEER 算 hash → GET
 /internal/v1/proxy-keys/by-hash。pepper 过短则网关启动失败。正缓存 30s、负缓存 2s ; 失败查找有
 AdmissionLimiter。过载 429 AUTH_OVERLOAD ; 未知/撤销对外同一 401
 INVALID_API_KEY (防枚举)。注意: 正缓存 30s 与「撤销 1s 内失效」规格存在张力。

10. 代理网关主链路（工作原理）

这是 2 小时分享的核心。实现集中在单个 Gin handler `handleProxy`，不是可插拔 Pipeline 包。PROXY_ENABLED≠0 时挂载。路径写死 volcano。

10.1 包地图

包	职责
httpserver	公开代理、内部 validate、包络、头脱敏
application	ChatService.Complete / OpenStream ; Validator (SF06)
domain/chatcompat	允许列表、过滤、usage 完整性、模型映射
domain/proxyauth	Bearer、HMAC、正负缓存、失败限流
domain/keypool	RR Pick、inflight、cooldown、Refresh
domain/keyhealth	30s 调度、失败 3 次才 down、429 停探 30min
domain/usageobs	完成观察、内存幂等、可选 JSON WAL
infrastructure/volcano	Chat 客户端、SSE 解析、NoopQuotaReader
infrastructure/apisvc	调 api-service 内部 HTTP，2s，X-Internal-Token

10.2 handleProxy 步骤

- `AuthenticateStatus(Authorization)`。失败：401 INVALID_API_KEY 或 429 AUTH_OVERLOAD。
- 读 body，上限 2MiB。`ParseRequestJSON`；未知顶层键或 $n \neq 1 \rightarrow 400$ INVALID_REQUEST。
- `Pool.Pick(buyerID)`：RR、Routable、排除自己、跳过冷却、 $\text{inflight} < \text{cap}$ 。失败 503 NO_AVAILABLE_KEY。
- 注入卖家 APIKey；生成服务端 usage event id（不等于客户端 X-Request-ID）。
- $\text{stream}=\text{false} \rightarrow \text{Complete}$ ； $\text{stream}=\text{true} \rightarrow \text{OpenStream}$ 。生成路径 `MaxAttempts=1`，禁止换 Key 重放。
- Observe 用量；defer `Pool.Release`；打 `proxy_requests_*` 指标。

10.3 选路算法（SF13 / SF14 / SF05）

```

for i in 0..n-1:
    idx = (idx + 1) % n          # ■■■■■■■■ RR
    skip if not Routable         # active ^ healthy ^ quota ■■ >0
    skip if SellerID == BuyerID  # ■■■■
    skip if now < coolUntil[id]   # ■■■ 429 ■■■■■ 30s
    skip if inflight[id] >= cap  # cap = floor(official*0.8) ■■■ 32
    inflight[id]++ ; return key
■■■ → 503 NO_AVAILABLE_KEY
defer Release

```

池每 1s 从 `/seller-keys/routable` 刷新（保留 inflight 计数）。多副本各自 RR，无跨实例原子游标，无 Redis。官方并未未知时保守 32。进程崩溃不会跨实例释放 inflight。

10.4 OpenAI 兼容（SF07）

出站允许字段：model, messages, stream, temperature, max_tokens, top_p, stop, presence_penalty, frequency_penalty, n=1。拒绝 tools / tool_choice / response_format / stream_options / user / seed / extra_body 等。messages[] 仅 role+content；content 原样 JSON。模型必须在 VOLCANO_V01_CHAT_MODELS；可用 VOLCANO_CHAT_MODEL_MAP 映射；响应回写公开 ID。缺截止默认 60s，最大 300s。买家请求头不转发。

10.5 usage 不得填 0

- 缺 usage 对象或缺分项 $\rightarrow$ missing，响应 omit/null，禁止 {0,0,0}。
- 负或 $\text{total} < \text{prompt} + \text{completion} \rightarrow$ inconsistent，保留原整数不改写。

- 三分项非负且 $\text{total} \geq \text{p} + \text{c} \rightarrow \text{complete}$ ，落库 `usage_source=official`。
- `choices` 可读仍算 `error_category=success`，与 `usage` 是否完整无关。

10.6 非流 vs 流

	非流	流 <code>stream=true</code>
适配	<code>Complete</code> $\rightarrow$ <code>NormalizeNonStream</code>	<code>OpenStream</code> + SSE parser，不 <code>ReadAll</code>
成功	200 OpenAI JSON	200 text/event-stream，chunk + 一次 data: [DONE]
连上游前失败	JSON 包络	尚未写 SSE 头 $\rightarrow$ JSON 包络
已出事件后失败	—	SSE error；不发 [DONE]； <code>truncated_stream</code>
用量失败	可变成 503 <code>USAGE_*</code> ，挡住成功响应	只能再写一条 SSE error

10.7 健康检查 (SF16)

每 30s 对 `administrative_state=active` 的 Key 调 SF06。`success` $\rightarrow$ `healthy`；`invalid/forbidden` $\rightarrow$ `invalid` (`invalid` 不会被非 `healthy` 结果改掉)；`zero quota` $\rightarrow$ `expired`；`429` $\rightarrow$ `rate_limited` 且 30min 不探；`timeout/5xx` 连续 3 次才 `down`。`paused/revoked` 不探。无多实例租约锁。

10.8 错误码

HTTP	code	场景
401	<code>INVALID_API_KEY</code>	代理 Key 无效/撤销/查找失败
429	<code>AUTH_OVERLOAD</code>	认证查找过载
400	<code>INVALID_REQUEST</code>	契约/未知字段/ $n \neq 1$
503	<code>NO_AVAILABLE_KEY</code>	池里没有可路由 Key
429	<code>RATE_LIMITED</code>	上游 429，可带 <code>Retry-After</code>
504	<code>UPSTREAM_TIMEOUT</code>	上游超时
502	<code>UPSTREAM_AUTH</code> / <code>UPSTREAM_ERROR</code>	上游 401/403 或其他
503	<code>USAGE_BACKPRESSURE</code> / <code>USAGE_DURABILITY</code>	用量 WAL 满或未持久化

11. 用量、日志与指标

11.1 用量观察 (SF17)

每个代理请求至多一次 `Observe`。`RequestId` 是网关生成的 event id；客户端 `X-Request-ID` 进 `ClientRequestId`。落库表 `usage_logs` (`api-service`，迁移 0006)。`幂等冲突 409`。V0.1 只记录，不估价、不扣款、不发 Kafka。没有 `estimated` 实现。

11.2 日志 (SF18)

JSON 结构化。入口记录 `method/path/request_id` + 允许列表头。适配完成 `provider_chat_complete` (`request_id/platform/stream/error_category/duration_ms/credential_ref`)。禁止记 `body`、`Bearer`、原始 Key。

11.3 指标与看板 (SF19)

代码定义 `proxy_requests_total{platform,stream,result}`、`duration`、`capacity_rejected`、`auth_failures`、`provider_usage_observe_total`、`health_check`、`key_inventory`、`provider_chat_*`。Grafana 预配「V0.1

代理总览」，无数据不得画成 0。告警：系统错误率 5 分钟 >5% 且样本 ≥ 20 ；可路由 Key=0。

采集缺口：公开 GET /metrics 使用独立 Registry，主要暴露 service_build_info；业务指标打在 prometheus.DefaultRegisterer。Prometheus 不在 SF02 compose 内，Grafana 数据源指向 host.docker.internal:9090。讲演时把「指标已埋点」和「本地默认刮不到」分开。

12. Billing / Admin

billing-service：live 不探库；ready 探 PostgreSQL；Alembic 0001 upgrade/downgrade 均为 pass，不建业务表。admin-service：live/ready 恒 200，无迁移、无业务路由、非 SF02 依赖探针对象。二者都不是 make dev 的一部分。

13. 基础设施与交付

13.1 SF02 本地中间件

仅 PostgreSQL 15.18、Redis 7.2、Grafana OSS 13.0，多平台 OCI digest 钉死。项目名 tokenmarket-<workspace-path-hash>。stdin 管道传入已验证的已提交 Compose 字节。普通 down 保留 PG/Redis 命名卷；Grafana 用 tmpfs。串行化生命周期操作。

13.2 分层 Compose (ADR 003)

层	文件	用途
L 本地依赖	compose.local.yml	只 PG/Redis/Grafana；禁止业务服务
中间件（部署）	compose.middleware.yml	同一三件套，供 deploy include
A 应用	compose.app.yml	五个已构建镜像
D 部署栈	compose.deploy.yml	include 中间件+应用；make deploy mode=test prod

make deploy 在适配器落地前 fail-closed (COMPONENT_NOT_INITIALIZED)。不要把业务服务扩进 compose.local.yml，也不要恢复根级全栈 compose 草图。

13.3 安全默认

- 真实配置只存在被忽略的 .env.local；.env.example 仅占位符。
- gitleaks / govulncheck / pip-audit / npm audit 失败关闭。
- 内部接口常量比较 X-Internal-Token；test/prod 的凭证验证 listener 必须回环。
- 卖家密文认证加密；代理 Key 只存 hash；会话只存 digest。

14. SF01–SF19 对照

ID	主题	主要落点
01	仓库工作流基线	根 Makefile、tools/workflow、ADR 001
02	本地依赖生命周期	make dev，ADR 002 Verified
03	用户注册	api-service + /register
04	手机登录会话	api-service + /login，Cookie
05	角色与自买自卖	authorization 域；网关 Pick 排除
06	火山凭证验证	网关内部 validate；额度 Noop
07	OpenAI 兼容	chatcompat 允许列表
08–09	卖家 Key 接入/生命周期	api-service sellerkeys；无前端
10	买家代理 Key	api-service proxykeys；无前端
11	代理 Key 认证	gateway proxyauth + by-hash
12 / 15	非流 / 流式代理	handleProxy Complete / OpenStream
13–14	Key 池与容量	keypool RR + inflight 80%
16	周期健康检查	keyhealth 30s
17	用量记录	usage_logs；不扣费
18	结构化日志	request_id + 脱敏
19	指标与看板	埋点 + Grafana JSON；Prometheus 不在 SF02

15. 已知张力（讲演必须说）

- 代理 Key 正缓存 30s vs 规格「撤销 1s 内失效」。
- 进程内 inflight，无跨实例租约 TTL。
- 池 Refresh 1s，多副本 RR 不保证全局公平。
- 公开 /metrics 与业务 DefaultRegisterer 可能不一致；本地无 Prometheus。
- 非流成功路径可能被用量持久化阻塞（先回客户端再异步落库的规格未完全对齐）。
- resource_ownerships 与真实 Key 表未双写。
- official_concurrency 内部 JSON 字段常为空，容量退回默认 32。
- Key HTTP 未走 AuthorizationService；网关不调 evaluate。
- DB 不可用时 Key 服务可 fallback 内存 store，重启丢失。
- 目标：Kafka、MinIO、扣费、Escrow、TMP、加权路由、三端业务页——不要画进现状。

16. 公开与内部 HTTP 全表

16.1 api-service 公开

方法	路径	要点
POST	/api/v1/auth/register	Idempotency-Key；不发会话
POST	/api/v1/auth/verification-challenges	202-before-dispatch；防枚举
POST	/api/v1/auth/sessions	Set-Cookie；csrf_token
GET	/api/v1/auth/session	bootstrap；现读角色
DELETE	/api/v1/auth/session	Origin + CSRF
POST	/api/v1/authorization/evaluate	忽略请求体身份字段
POST	/api/v1/authorization/route-candidates/exclude-self	过滤自有 Key
POST/GET/PATCH	/api/v1/authorization/fixtures/*	仅 local test
POST/GET	/api/v1/seller-keys	seller/both；写操作 CSRF
POST	/api/v1/seller-keys/{id}/pause resume revoke	状态机
POST/GET	/api/v1/proxy-keys	buyer/both；明文只回一次
POST	/api/v1/proxy-keys/{id}/revoke	status=revoked

16.2 网关 ↔ api-service 内部

方向	路径	用途
网关 → API	GET /internal/v1/proxy-keys/by-hash	HMAC 查找
网关 → API	GET /internal/v1/seller-keys/routable	解密后的可路由 Key
网关 → API	POST /internal/v1/seller-keys/{id}/health	健康写回
网关 → API	POST /internal/v1/usage-observations	用量观察
API → 网关	POST /internal/v1/provider-credentials/validate	卖家接入探活
客户端 → 网关	POST /v1/proxy/volcano/chat/completions	公开代理

16.3 运维面

五服务均有 GET /health/live、GET /health/ready、GET /metrics。仅 API/Billing 的 ready 探 PostgreSQL。网关公开代理可被 PROXY_ENABLED=0 关闭。

17. 关键配置（失败关闭）

变量	谁读	失败关闭行为
DATABASE_URL	API / Billing	ready 503；注册等写路径不可用
REDIS_URL	API 限流	限流依赖缺失则 fail-closed
PROXY_AUTH_PEPPER	网关	过短则进程启动失败
INTERNAL_GATEWAY_TOKEN	双方内部	内部 401
PROVIDER_VALIDATE_*	网关 SF06	非 local 非回环 bind 则启动失败
VOLCANO_V01_CHAT_MODELS	网关 SF07	不在名单的 model 拒绝
SELLER 密钥环	API	test/prod ready 检查密钥环
CORS_ALLOW_ORIGINS	API	默认 Vite 本地 Origin，精确匹配

18. 卖家接入时序

```

■■■■(■■ UI / curl) POST /api/v1/seller-keys
  ■ Cookie + CSRF + Idempotency-Key
  ▼
api-service OnboardingService
  ■ ■■■■■ · ■ volcano
  ▼
gateway POST /internal/v1/provider-credentials/validate
  ■ GET {VOLCANO}/models 3s ■■■■
  ■ NoopQuotaReader → quota_unavailable■■■■ 0■
  ▼
■■■■■■ seller_api_keys■nonce/ct/tag/key_version■
  ■ fingerprint ■■
  ▼
■■■ masked_hint■■■■■■

```

19. 代理请求时序

```

Client Authorization: Bearer tmk-...
POST /v1/proxy/volcano/chat/completions
■
■■■ HMAC(pepper, secret) → by-hash■■■■ 30s / ■■■ 2s■
■■■ ParseRequestJSON + allowlist■■■■ 400■
■■■ Pick: RR · Routable · exclude self · cooldown · inflight
■■■ ■■ seller APIKey■usage event id ≠ X-Request-ID
■■■ stream? OpenStream : Complete MaxAttempts=1
■■■ usage missing → omit■■■■ {0,0,0}
■■■ Observe → usage_logs■official | not_available■
■■■ Release inflight · metrics

```

20. Alembic 表 (API 链)

修订	表
0001	空 baseline
0002	users · registration_idempotency_records
0003	verification_* · auth_sessions · authentication_security_events
0004	resource_ownerships · authorization_security_events · audit_outbox
0005	seller_api_keys (密文分列)
0006	proxy_keys · usage_logs · usage_conflicts
0007	actor-scoped 幂等主键 (seller_id/buyer_id, key)

Billing 0001 upgrade/downgrade 均为 pass。Admin 无迁移。

21. 阅读清单

先读	路径
现状数据流	docs/architecture/overview.md
目标架构	项目开发/1-项目架构与目录结构.md
网关规范	项目开发/2-Go代理网关开发规范.md
Python / 数据	项目开发/3-Python后端与数据库设计规范.md
前端与交付	项目开发/4-前端与DevOps监控规范.md
子 Spec 索引	项目开发/V0.1/V0.1_0712/specs/README.md
宪章	.specify/memory/constitution.md
契约总表	shared/contracts/README.md

先读	路径
ADR	docs/decisions/README.md
本目录 PPT	项目开发/技术架构/TokenMarket_技术架构.pptx

配套分享 PPT 按 2 小时编排：前 30 分钟全景与契约，中间 70 分钟身份 / Key / 网关工作原理，后 20 分钟观测、交付与张力。数字与本文同一套，不以目标架构冒充现状。